27/08/26

Case study - 1

1. write brightmart is a ~~for~~ medium size online shopping company. Customer used is website and mobile Application to purchase products.

Q.1 The Company ~~sould~~ store

1. Customers name.
2. Email addresses.
3. Phone numbers.
4. delivery addresses.
5. password.
6. order information.
7. Payment - related information.

Bright mart has around 100 Empolyees.

The Company recently hired several new Empolyee. To Make things easier, the IT Department give Empolyee access To different Internal Systems.

However, the Company has the following Security weakness.

- Some Empolyee use simple passwords such as Brightmart 123.
- many Empolyee use the same password for multiple systems.

Stage 1:- Unauthorised Access

The attacker user Rahul's Confidentials to access BrightMart's Internal System. Because rahul uses ~~one~~ the same password for another. System, the attackers is also able to access that System.
The attacker discovers that Rahul has access to Customer information.
The attacker downloads a large amount of Customer data.

Q. What Cybersecurity problem has occured?

Stage 2:- Malware attack

The attackers send another to Rahul Email to Rahul Containg a malicious attachment.
Rahul opens the attachmeur.
Malware is Installed.
The malware begins Communication with the attackers System.
The attacker ~~now~~ now attempts to move from rahul's Computer to another Systems within Brightmart's networks.

Q. Which vulnerability allowed the attacker to move further into the organisation?

Stage 3:- Ransomware.

- Software updates are sometimes delayed.
- The company does not regularly conduct Employee Cybersecurity training.
- There is no multi-factors authentication for some important accounts.
- Employees can access sensitive information that they do not necessarily need for their jobs.
- Backups are performed only once a month.

The Incident.

One Monday morning, an Employee named Rahul receives an Email.

Subject :- Urgent – your Account will be Suspended.

The email appears to come from the company's IT department.
It says:

"your company account will be suspended today. Click the below and verify your password immediately."

Rahul clicks the link.
The page looks almost identical to the Company's login page.
He enters his username and password.
Rahul does not realize that the website is controlled by an attacker.
The attacker now has Rahul's login Credentials.

Two days later, employees arrives at work and discover that they cannot access important files.

A message appears on their computers "your files have been encrypted, pay the ransom to recover them".
The company's customer database and several important business files are encrypted. Unfortunately, the company's most recent backup is almost a month old. Brightmart's website stops working. Customers cannot place orders. The customer support team cannot access customer needs.

Stage 4 — Business Impact

Brightmart now faces several problems.

Financial Impact → The company losses sales because its website is unavailable.

Data Impact → Customer information may have been stolen.

Operational Impact → Employees cannot access important systems.

Reputation Impact → Customers lose confidence in the company.

Legal / compliance Impact → The company may face regulatory or legal consequences depending on what information was exposed and which laws apply.

* GROUP - 1 → Identify the threats

what threats are present in this case?

* GROUP - 2 → Identify the vulnerabilities

what weaknesses in Brightmart's security allowed the attack to succeed?

* GROUP-3 → Apply the CIA Triad

was confidential information exposed?
was Information changed or damaged?
were Systems available to legitimate users?

* GROUP - 4 → Solutions Security

Ques 1 → who is responsible for Cybersecurity?
Ques 2 → was Phising the only problem?
Ques 3 → what was the biggest vulnerability?

Quick Assessment

At the end, ask Student to answer these 5 questions Individually:

2. Give three vulnerability that helped the attacker

3. Which three Security principles of the CIA Triad were affected?

4. What was the Impact of ransomware on Brightmart?

5. Suggest three Security Controls Brightmart should Implement.

ANSWERS

1. What Cybersecurity Problem has occured?

- pishing
- Credential theft
- unauthorized access
- Data breach

* which vulnerability allowed the attacker to move further into the organisation

- weak password
- Excessive user privileges
- lack of MFA
- Poor Network Security
- lack of Empolyee awarness
- Outdated Software.

* What threats are present in this case?
They may Identify:

- Phishing.
- Malware
- Ransomware.
- Credential theft.
- Unauthroized access.

Data theft

* what weaknesses in Bvightmart's Security allowed the attack to succeed?

Vulnerability	How it helped the attacker
weak passwords	Easier to Compromise accounts
Password reuse	one Stolen password gives access to multiple Systems.
No MFA	Stolen Password May be Enough to log in
Lack of Training	Empolyee fails for phishing
Delayed updates	vulnerable software may be Expired.
Excessive privileges	Attacker Can access more data

Infrequent Backups difficult to recover after ransomware

Confidentiality

& was Confidentaity Informed exposed?

→ yes
Coustomer information was accessed / downloaded By the attacker.

Integrity

& was information changed or damaged?

→ Potentially yes.
The attacker could Modify or Encrypt files.

Availability

& were systems available to legitimate users?

→ No.
The website and internal System became unavailable because of ransomware.

So:-
Confidentiality → Affected.
Integrity → Affected.
Availability → Affected.

GROUP-4 Security Solutions

What should Brightmart do to prevent this from happening again?

Students could suggest:

- use strong passwords.
- Implement multi-factor Authentication [MFA]
- Provide regular cybersecurity awareness train
- Conduct phishing-awareness excercise.
- Keep Software updated.
- follow the Principal of least privilege.
- Segment important networks.
- Maintain regular backups.
- Encrypt Sensitive data.
- Deploy antivirus / Endpoint protection.
- Monitor suspicious login activity.
- Develop an Incident-response plan

* who is responsible for cybersecurity?

Expected discussion:
Not only the IT department. Every Employee who uses the organization's System has a role in cybersecurity.

Question 2:-

was Phising the only Problem?

→ No.
pishing was the initial attack, but weakness-es such as password reuse, lack of MFA,

Excessive privileges, poor backups, and insufficient training allowed the attack to become much more damaging.

Question 3:

* What was the Biggest vulnerability?

→ There is no single correct answer. Students should justify their choice.

Ex:-

"Lack of Employee awareness was a Major vulnerability because the attack started when Rahul clicked the phishing link".

Another Student might argue.

"Poor Backup Practice were the Biggest Problem Because Brightmart could not quickly recover from ransomware."

Both can be valid if properly Justified.

Quick Assessment:

1→ It was a phishing attack. Rahul got an email pretending to be from IT, saying his account would be suspended he clicked the link, landed on a fake

login page, and typed in his username and password. Handing his credentials Straight to the attacker.

2→ • Password reuse → Rahul used the same password on another System, so the attacker got into that one too

• No MFA → Some important accounts had no multi-factor authentication, so the ~~attacker~~ stolen password was enough.

• Excessive privilges - Rahul has access to customer data he didn't actually need for his job, so the breach Spread further than it should have.

3→ • Confidentiality → Customer data (names, emails, passwords, payment info) was exposed / Stolen.

• Integrity → The ransomware encrypted files, altering their original State

• Availability → The website went down and employee / customers couldn't access Systems or place orders

4→ • Financial → lost Sales since the website was down.

2. Data → Customer information may have been stolen.

- Operational → Empolyees couldn't access key systems or customer records.
- Reputation → Customers lost trust in the company.
- Legal / Compliance → possible regulatory or legal trouble depending on what data was exposed.

→ Multi-factor Authentication (MFA) :- On all critical accounts, so a stolen password alone isn't enough.

- frequent, tested backups :- [Daily / weekly, kept offline] the monthly backup meant they lost nearly a month of data.
- least privilege access → give Empolyees only the access they need, and teach them to spot phishing attempts.

Attackers Exploit Systems, Networks and Human Psychology

1. Dos and ddos (Denial-of-Service)

Overwhelming a target server with massive traffic from compromised systems until legitimate users cannot access the website.

2. Man-in-the-Middle (MITM)

positioning secretly between communicating parties to intercept or manipulate data

3. Social Engineering & phising

Bypassing technical defenses entirely Exploiting human trust, fear or urgency to steal passwords.

phases of hacking

1. foot printing → collection of information on victim as much as possible.

2. Scanning → Checking whether information collected is right or wrong.

3. gaining excess to victims Computer/or System

4. Maintaining the access till your goal is acheived.

5 Cleaning tracks → Cleaning the evidences of your existing

* types of attacks

1. White hat attackers → attacks to secure (legal)

2. Black hat attackers → find vulnerability then report to concern authority and asked money If they failed to give money they leak the data Second sub of Black hat hackers is to send numerous request at a time to the server In order to put the server or website down